

Vishal Raavi

240-854-2384 - vishalraavi.work@gmail.com - linkedin.com/in/vishalraavi

Education

University of Maryland, College Park

Master of Engineering in Cybersecurity (GPA: 3.88/4.0)

Relevant Coursework: Cloud Security, Penetration testing, Security tools, Secure Software Design

College Park, MD

Jan 2024 - Dec 2025

Certifications & Security Training

- OffSec Certified Professional OSCP - OSID57747451, Earned 2026
- Burp Suite Certified Practitioner (BSCP) - PortSwigger, In Progress
- Software Design Threats and Mitigations - University of Colorado System
- Software Design as an Element of the Software Development Lifecycle - University of Colorado System

Professional Experience

University of Maryland

Software Security Engineer - Product Security

College Park, MD

Apr 2024 - Present

- Integrated **application security** into the **Secure SDLC**, reviewing attack surface, trust boundaries, REST APIs, user-controlled inputs, browser behavior, file-processing paths, and externally exposed functionality during design, development, and release.
- Performed manual and dynamic application security testing using **Burp Suite** across API endpoints, authentication and authorization flows, session handling, input validation, CORS behavior, and business logic; reproduced findings and validated security impact before remediation.
- Conducted **OWASP Top 10** reviews of the application codebase and remediated XSS, Insecure Design, input-validation, and cross-origin weaknesses using server-side/client-side validation, CORS hardening, DOM-safe handling, and stronger application boundaries, reducing software defects by 50%.
- Designed and implemented token-authenticated Flask REST APIs and access-controlled application workflows, strengthening **authentication, authorization, API security, and session boundaries** for externally accessible functionality.
- Performed **threat modeling and security design reviews** across frontend/backend data flows, service integrations, privilege boundaries, and abuse cases, identifying high-risk attack paths early and translating them into engineering controls.
- Worked with developers and researchers on **vulnerability triage and remediation**, performing root-cause analysis, recommending code-level fixes, and retesting changes before release to verify remediation and prevent regression.
- Secured REST API and service integrations with schema and payload validation, structured error handling, controlled data exchange, and defensive input processing to block malformed or untrusted data and reduce application attack surface.
- Architected and developed production software using React.js, Flask, Python, REST APIs, and Docker, building backend services and integrations while improving serialization and request handling to reduce application response time by 50%.
- Integrated GitHub Actions, CI/CD, Docker, Bash/Shell automation, application logging, and standardized deployment workflows, improving release reliability, deployment security, logging visibility, and secure configuration management.

Sathayush Technologies

Application Security Engineer

Hyderabad, India

Nov 2022 - Dec 2023

- Performed manual and automated security assessments of 100+ production web applications and REST APIs, identifying SQL injection, XSS, CSRF, IDOR, authentication/authorization bypasses, insecure file handling, and security misconfigurations using Burp Suite, Nmap, and custom payloads.
- Conducted application security reviews across authentication, authorization, user-controlled inputs, API endpoints, session management, business logic, and sensitive-data exposure; provided developers with remediation guidance for confirmed findings.
- Worked with software engineers on vulnerability remediation, reproducing findings, performing root-cause analysis, explaining security impact, recommending secure implementation changes, and retesting fixes before closure.
- Conducted threat modeling, attack-surface analysis, and security design reviews for web and cloud-hosted applications, evaluating trust boundaries, exposed services, application data flows, and high-risk attack paths to prioritize security controls based on likelihood and potential impact.
- Built Python and Bash security tooling for reconnaissance, endpoint discovery, fuzzing, and payload testing, increasing coverage and reserving manual analysis for higher-risk application functionality.
- Performed internal and external infrastructure assessments, validating SMB/LDAP and identity misconfigurations with Metasploit, NetExec, and BloodHound to assess application and product security impact.

Technical Skills

- **Application & Product Security:** Secure SDLC, Threat Modeling, Attack Surface Analysis, Security Architecture & Design Review, Secure Code Review, Web/API Security, Vulnerability Management, Remediation Validation, Security Retesting
- **Application Security Testing:** DAST, Burp Suite, OWASP Top 10, SQL Injection, XSS, CSRF, IDOR, Authentication/Authorization Testing, Session Management, File Upload Security, CORS, Business Logic Testing
- **Advanced Web Security:** API Testing, Access Control, SSRF, JWT Security, HTTP Request Smuggling, Web Cache Issues, Path Traversal, XXE, Command Injection
- **Security Tools:** Burp Suite, BloodHound, Impacket, NetExec, Chisel, WinPEAS, LinPEAS, msfvenom, Nmap, SQLmap, Wireshark
- **Security Automation:** Python, Bash/Shell, Recon, Endpoint Discovery, Fuzzing, Payload Testing, Custom Payloads
- **Programming & Web:** Python, Java, JavaScript, SQL, HTML, CSS, React.js, Node.js, Flask, RESTful APIs
- **DevSecOps & Engineering:** Git, GitHub Actions, CI/CD, Docker, Bash/Shell, Secure Deployment, Logging
- **Cloud & Infrastructure Security:** AWS EC2, S3, RDS, VPC, ALB, CloudFront, Route 53, WAF, IAM, KMS, ACM, CloudWatch, CloudTrail, VPC Flow Logs, Security Groups, NACLs
- **Frameworks & Hardening:** OWASP Top 10, STRIDE, DREAD, NIST CSF, CIS Benchmarks, Least Privilege, RBAC/ACLs, Network Segmentation, SELinux, UFW, Patch Management
- **Operating Systems:** Linux (Ubuntu, Kali Linux), Windows, macOS

My OSCP Journey

From Security Fundamentals to OSCP

- Started the PEN-200 path from security fundamentals and gradually built hands-on confidence across reconnaissance, web exploitation, Linux and Windows privilege escalation, password attacks, tunneling, pivoting, and Active Directory.
- Learned to work through machines as complete attack paths rather than isolated vulnerabilities, moving from enumeration and initial access to privilege escalation, credential discovery, lateral movement, and post-exploitation.
- Developed my own repeatable workflow using BloodHound, Impacket, Chisel, NetExec, WinPEAS, LinPEAS, msfvenom, Burp Suite, Nmap, and Wireshark, using tools to support enumeration and validation rather than relying on a single automated path.
- Earned the OSCP in 2026 after extensive hands-on practice, with the biggest improvement being a more methodical approach to enumeration, troubleshooting failed paths, and revisiting assumptions when an exploit or privilege-escalation route did not work.
- Continued practicing hands-on **CTF and OSCP lab boxes** across web, Linux, Windows, and Active Directory environments to strengthen exploitation, privilege escalation, credential attacks, pivoting, and lateral movement.

Projects

Secure AWS E-Commerce Platform - Application & Cloud Security

- Designed and deployed a scalable e-commerce environment on AWS using EC2, ALB, Auto Scaling, RDS, S3, CloudFront, Route 53, and VPC networking, with WAF, ACM, KMS, Security Groups, and NACLs providing layered application and infrastructure protection.
- Performed application and cloud security reviews across IAM permissions, EC2 hardening, authentication boundaries, network controls, encryption, logging, and patching; identified exposed secrets, insecure file permissions, firewall gaps, and host-hardening weaknesses.
- Implemented and recommended remediation using least-privilege IAM, HTTPS/TLS, encryption at rest, CloudWatch, CloudTrail, VPC Flow Logs, and stronger host/network controls, prioritizing fixes by exploitability, severity, and potential blast radius.
- Documented realistic attack paths from exposed credentials and cloud misconfigurations to privilege escalation and data exposure, linking findings to practical remediation and monitoring controls.

Secure Application Infrastructure, Threat Modeling & Security Monitoring

- Architected and deployed a 2-tier LAMP environment across Ubuntu servers, separating web and database tiers and configuring Apache, PHP, MySQL, and application connectivity across segmented hosts.
- Hardened the environment using least-privilege RBAC/ACLs, restricted SSH access, service-specific UFW rules, and network segmentation to limit unauthorized access and lateral movement between the web and database tiers.
- Applied STRIDE threat modeling to classify 16 vulnerabilities across application and infrastructure trust boundaries, then used DREAD scoring across 12 threat scenarios to prioritize high-risk attack paths and map findings to security controls.
- Extended the environment with centralized security monitoring using Filebeat, Elasticsearch, and Kibana, ingesting 17.4M+ SSH and web events for real-time investigation while restricting the logging tier to required service ports only.